

INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

INGENIERÍA EN SISTEMAS COMPUTACIONALES
ACADEMIA DE SISTEMAS DISTRIBUIDOS

Computer Security

Práctica No. 1

Sistema Operativo Linux: Fundamentos en la Seguridad Informática

ALUMNO

Luis Andrés Contla Mota

BOLETA

2022630540

GRUPO

6CV3

PROFESOR

Rodrigo Ojeda Santillán

OBJETIVO

Medir y analizar la brecha de seguridad existente entre una instalación por defecto de un sistema operativo Linux y un entorno rigurosamente hardenizado, aplicando estándares de la industria y metodologías de defensa en profundidad. El propósito es evolucionar de configuraciones base, frecuentemente vulnerables a ataques automatizados y explotación de configuraciones deficientes, hacia una postura de seguridad proactiva. Esto implica la implementación práctica de herramientas de auditoría modernas (como Lynis y OpenSCAP) para evaluar el cumplimiento de perfiles reconocidos, específicamente el CIS Level 1 Server. Asimismo, se busca aplicar controles restrictivos a nivel de kernel, red y espacio de usuario, abarcando la modernización del acceso remoto mediante criptografía post-cuántica en SSH, la transición de iptables a nftables para el filtrado de red, y el confinamiento estricto de demonios utilizando las capacidades de sandboxing nativas de systemd y el control de acceso obligatorio de AppArmor. Finalmente, el objetivo abarca la comprensión de la seguridad en la cadena de suministro de software mediante el análisis de contenedores rootless, escaneo de vulnerabilidades y la generación de inventarios de software (SBOM).

INTRODUCCIÓN

El panorama de la seguridad en sistemas Linux ha experimentado transformaciones radicales en los últimos años, alejándose de los paradigmas tradicionales de defensa perimetral para adoptar arquitecturas de zero-trust y mitigaciones integradas a nivel del núcleo. La administración moderna de servidores exige un conocimiento profundo de los mecanismos de endurecimiento que van más allá de las simples actualizaciones de paquetes. Históricamente, las distribuciones Linux priorizaban la usabilidad y la retrocompatibilidad sobre la seguridad estricta, lo que se traducía en servicios con privilegios excesivos, algoritmos criptográficos obsoletos y una superficie de ataque interna amplia.

En la actualidad, estándares como los Benchmarks del Center for Internet Security (CIS) proporcionan marcos de referencia auditables, con cientos de controles específicos que van desde el aislamiento de particiones hasta la configuración de parámetros del kernel (sysctl) que mitigan vectores de explotación avanzados, como el secuestro del flujo de control o ataques de corrupción de memoria. Un cambio fundamental en esta evolución es la adopción generalizada de eBPF (Extended Berkeley Packet Filter), que ha desplazado a herramientas clásicas como auditd para la telemetría y detección de amenazas en tiempo real. eBPF permite la ejecución segura de programas dentro del kernel, otorgando visibilidad sin precedentes sobre las llamadas al sistema y la actividad de la red, con un impacto mínimo en el rendimiento, y solucionando vulnerabilidades inherentes a los enfoques de monitoreo en el espacio de usuario (como los ataques TOCTOU).

Paralelamente, la criptografía se encuentra en una fase de transición crítica frente a la amenaza de la computación cuántica ("store now, decrypt later"). Servicios críticos como SSH han adoptado por defecto algoritmos de intercambio de claves post-cuánticos, depreciando definitivamente claves débiles y forzando la adopción de esquemas de curvas elípticas. En el ámbito de la red, nftables ha reemplazado oficialmente a iptables, unificando el filtrado de IPv4 e IPv6 bajo una misma sintaxis y permitiendo actualizaciones atómicas de reglas, lo cual es vital para prevenir estados inconsistentes del firewall durante la mitigación de ataques volumétricos.

A nivel de aplicaciones y servicios, el concepto de mínimo privilegio se ha materializado mediante el sandboxing profundo proporcionado por systemd y por tecnologías de contenedores como Podman. Systemd permite restringir el acceso de los demonios a la red, aislar sistemas de archivos enteros y denegar explícitamente capacidades del kernel (*capabilities*), lo que reduce drásticamente el impacto de un compromiso. Por su parte, la seguridad en la cadena de suministro se ha vuelto un requisito ineludible. La validación de imágenes de contenedores mediante SBOMs (Software Bill of Materials) y herramientas de análisis estático garantiza que no se hereden vulnerabilidades críticas de bibliotecas de terceros o de componentes comprometidos en el origen. En conjunto, estos elementos

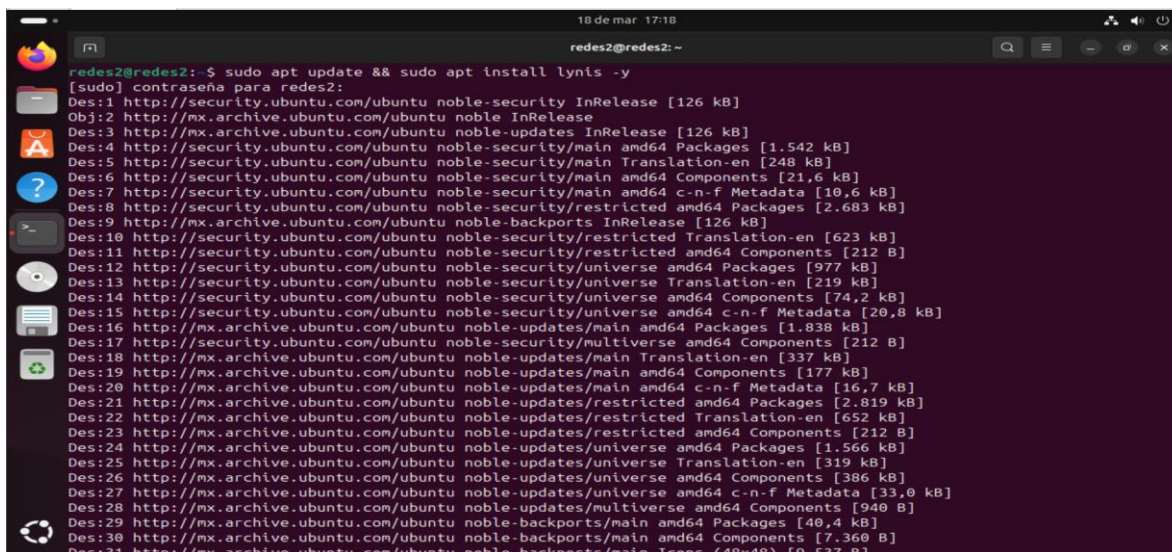
constituyen el estándar de facto para la administración segura de la infraestructura Linux contemporánea.

DESARROLLO

Laboratorio 1. Auditoria de Seguridad con Lynis

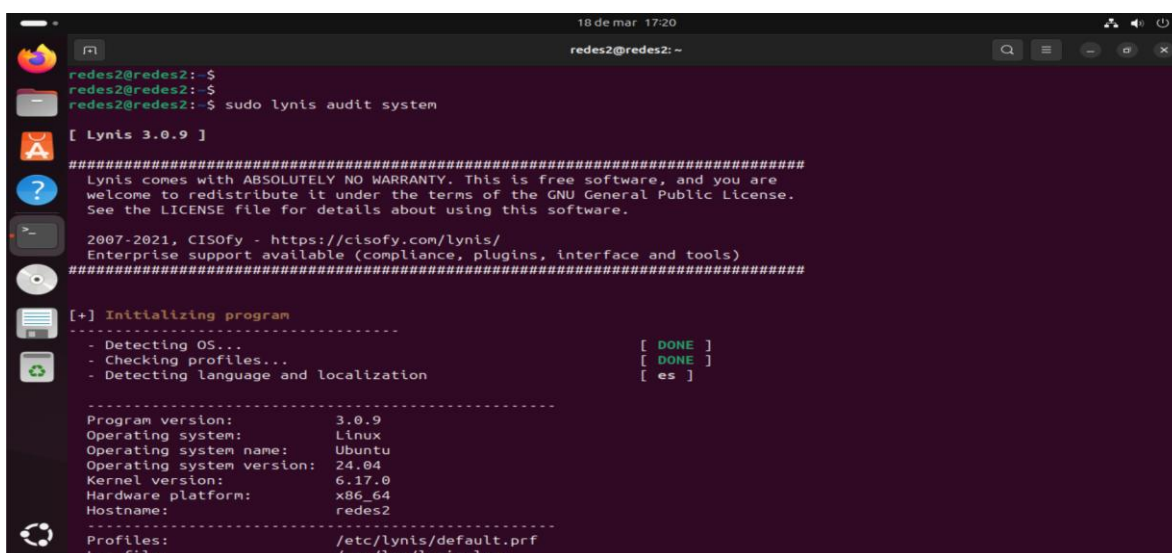
Objetivo: Medir la brecha entre una instalación por defecto y un sistema hardenizado.

Se instaló Lynis y se ejecutó *sudo lynis audit system*.



```
redes2@redes2:~$ sudo apt update && sudo apt install lynis -y
[sudo] contraseña para redes2:
Des:1 http://security.ubuntu.com/ubuntu noble-security InRelease [126 kB]
Obj:2 http://mx.archive.ubuntu.com/ubuntu noble InRelease
Des:3 http://mx.archive.ubuntu.com/ubuntu noble-updates InRelease [126 kB]
Des:4 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages [1.542 kB]
Des:5 http://security.ubuntu.com/ubuntu noble-security/main Translation-en [248 kB]
Des:6 http://security.ubuntu.com/ubuntu noble-security/main amd64 Components [21,6 kB]
Des:7 http://security.ubuntu.com/ubuntu noble-security/main amd64 c-n-f Metadata [10,6 kB]
Des:8 http://security.ubuntu.com/ubuntu noble-security/restricted amd64 Packages [2.683 kB]
Des:9 http://mx.archive.ubuntu.com/ubuntu noble-backports InRelease [126 kB]
Des:10 http://security.ubuntu.com/ubuntu noble-security/restricted Translation-en [623 kB]
Des:11 http://security.ubuntu.com/ubuntu noble-security/restricted amd64 Components [212 B]
Des:12 http://security.ubuntu.com/ubuntu noble-security/universe amd64 Packages [977 kB]
Des:13 http://security.ubuntu.com/ubuntu noble-security/universe Translation-en [219 kB]
Des:14 http://security.ubuntu.com/ubuntu noble-security/universe amd64 Components [74,2 kB]
Des:15 http://security.ubuntu.com/ubuntu noble-security/universe amd64 c-n-f Metadata [20,8 kB]
Des:16 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 Packages [1.838 kB]
Des:17 http://security.ubuntu.com/ubuntu noble-security/multiverse amd64 Components [212 B]
Des:18 http://mx.archive.ubuntu.com/ubuntu noble-updates/main Translation-en [337 kB]
Des:19 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 Components [177 kB]
Des:20 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 c-n-f Metadata [16,7 kB]
Des:21 http://mx.archive.ubuntu.com/ubuntu noble-updates/restricted amd64 Packages [2.819 kB]
Des:22 http://mx.archive.ubuntu.com/ubuntu noble-updates/restricted Translation-en [652 kB]
Des:23 http://mx.archive.ubuntu.com/ubuntu noble-updates/restricted amd64 Components [212 B]
Des:24 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 Packages [1.566 kB]
Des:25 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe Translation-en [319 kB]
Des:26 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 Components [386 kB]
Des:27 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 c-n-f Metadata [33,0 kB]
Des:28 http://mx.archive.ubuntu.com/ubuntu noble-updates/multiverse amd64 Components [940 B]
Des:29 http://mx.archive.ubuntu.com/ubuntu noble-backports/main amd64 Packages [40,4 kB]
Des:30 http://mx.archive.ubuntu.com/ubuntu noble-backports/main amd64 Components [7.360 B]
Des:31 http://mx.archive.ubuntu.com/ubuntu noble-backports/main Trans (48x48) [9.537 B]
```

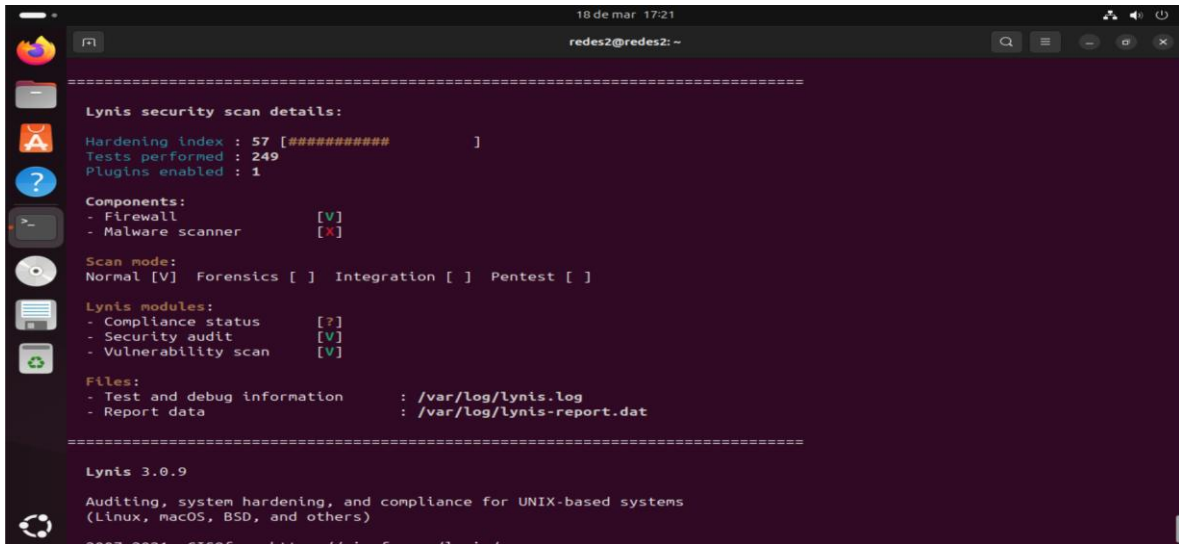
Ilustración 1 - Instalación de Lynis



```
redes2@redes2:~$ sudo lynis audit system
[ Lynis 3.0.9 ]
#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.
#####
2007-2021, CISOFy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####
[+] Initializing program
-----
- Detecting OS... [ DONE ]
- Checking profiles... [ DONE ]
- Detecting language and localization [ es ]
-----
Program version: 3.0.9
Operating system: Linux
Operating system name: Ubuntu
Operating system version: 24.04
Kernel version: 6.17.0
Hardware platform: x86_64
Hostname: redes2
-----
Profiles: /etc/lynis/default.prf
Log file: /var/log/lynis.log
```

Ilustración 2 - Ejecución de Lynis

El sistema arrojó un **Hardening Index de 57**, lo que indica una postura de seguridad media-baja en una instalación estándar.



```
=====
Lynis security scan details:
=====
Hardening index : 57 [#####          ]
Tests performed : 249
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit    [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

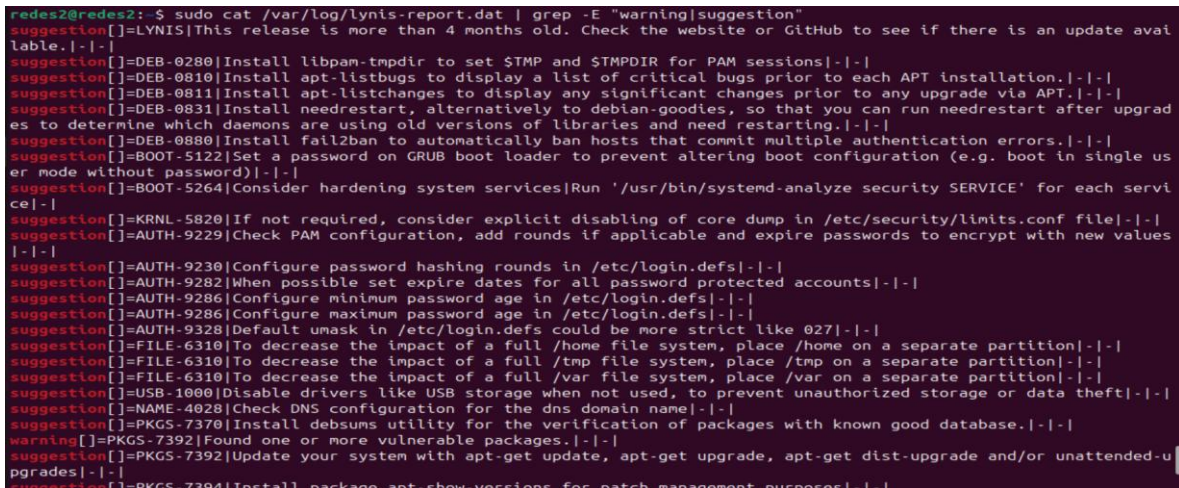
=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021 - CISOFY - https://cisofy.com/lynis/
```

Ilustración 3 - Resultados del escaneo



```
redes2@redes2:~$ sudo cat /var/log/lynis-report.dat | grep -E "warning|suggestion"
suggestion[ ]=LYNIS|This release is more than 4 months old. Check the website or GitHub to see if there is an update available.|-|-|
suggestion[ ]=DEB-0280|Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions|-|-|
suggestion[ ]=DEB-0810|Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|-|
suggestion[ ]=DEB-0811|Install apt-listchanges to display any significant changes prior to any upgrade via APT.|-|-|
suggestion[ ]=DEB-0831|Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are using old versions of libraries and need restarting.|-|-|
suggestion[ ]=DEB-0880|Install fail2ban to automatically ban hosts that commit multiple authentication errors.|-|-|
suggestion[ ]=BOOT-5122|Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password).|-|-|
suggestion[ ]=BOOT-5264|Consider hardening system services|Run '/usr/bin/systemd-analyze security SERVICE' for each service|-|-|
suggestion[ ]=KRNL-5820|If not required, consider explicit disabling of core dump in /etc/security/limits.conf file|-|-|
suggestion[ ]=AUTH-9229|Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values|-|-|
suggestion[ ]=AUTH-9230|Configure password hashing rounds in /etc/login.defs|-|-|
suggestion[ ]=AUTH-9282|When possible set expire dates for all password protected accounts|-|-|
suggestion[ ]=AUTH-9286|Configure minimum password age in /etc/login.defs|-|-|
suggestion[ ]=AUTH-9286|Configure maximum password age in /etc/login.defs|-|-|
suggestion[ ]=AUTH-9328|Default umask in /etc/login.defs could be more strict like 027|-|-|
suggestion[ ]=FILE-6310|To decrease the impact of a full /home file system, place /home on a separate partition|-|-|
suggestion[ ]=FILE-6310|To decrease the impact of a full /tmp file system, place /tmp on a separate partition|-|-|
suggestion[ ]=FILE-6310|To decrease the impact of a full /var file system, place /var on a separate partition|-|-|
suggestion[ ]=USB-1000|Disable drivers like USB storage when not used, to prevent unauthorized storage or data theft|-|-|
suggestion[ ]=NAME-4028|Check DNS configuration for the dns domain name|-|-|
suggestion[ ]=PKGS-7370|Install debsums utility for the verification of packages with known good database.|-|-|
warning[ ]=PKGS-7392|Found one or more vulnerable packages.|-|-|
suggestion[ ]=PKGS-7392|Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or unattended-upgrades|-|-|
suggestion[ ]=PKGS-7394|Install package apt-show-versions for patch management purposes|-|-|
```

Ilustración 4 - Logs de los resultados

Con estos resultados, procedemos a elegir 5 sugerencias para corregirlas y aumentar el hardening.

1. PKGS-7392: Actualizar paquetes vulnerables

Se ejecutó `sudo apt-get upgrade` para mitigar vulnerabilidades conocidas en paquetes desactualizados.


```
redes2@redes2:~$ sudo apt-get update
Obj:1 http://mx.archive.ubuntu.com/ubuntu noble InRelease
Obj:2 http://security.ubuntu.com/ubuntu noble-security InRelease
Obj:3 http://mx.archive.ubuntu.com/ubuntu noble-updates InRelease
Obj:4 http://mx.archive.ubuntu.com/ubuntu noble-backports InRelease
Leyendo lista de paquetes... Hecho
redes2@redes2:~$ sudo apt-get upgrade -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Calculando la actualización... Hecho
Las siguientes actualizaciones se han retenido debido a actualizaciones paulatinas (phasing):
binutils binutils-common binutils-x86-64-linux-gnu libbinutils libctf-nobfd0 libctf0 libgprofng0 libstdc++6
Los siguientes paquetes se han retenido:
linux-generic-hwe-24.04 linux-headers-generic-hwe-24.04 linux-image-generic-hwe-24.04
Se actualizarán los siguientes paquetes:
bsdextrautils bsdutils cloud-init coreutils eject fdisk gir1.2-gtk-4.0 gir1.2-nm-1.0 libblkid1 libcurl3t64-gnutls
libcurl4t64 libexiv2-27 libfdisk1 libfprint-2-2 libfprint-2-tod1 libfreerdp-server3-3 libfreerdp3-3 libfreetype6
libgphoto2-6t64 libgphoto2-l10n libgphoto2-port12t64 libgtk-4-1 libgtk-4-bin libgtk-4-common
libgtk-4-media-gstreamer libmount1 libmtp-common libmtp-runtime libmtp9t64 libnftables1 libnm0 libsmartcols1
libssh-4 libuuid1 libwinpr3-3 linux-base linux-libc-dev linux-tools-common mount network-manager
network-manager-config-connectivity-ubuntu network-manager-openvpn network-manager-openvpn-gnome nftables
openssh-client openvpn python3-cryptography python3-software-properties rtkit snapd software-properties-common
60 actualizados, 0 nuevos se instalarán, 0 para eliminar y 11 no actualizados.
Se necesita descargar 64,6 MB de archivos.
Se utilizarán 328 kB de espacio de disco adicional después de esta operación.
Des:1 http://security.ubuntu.com/ubuntu noble-security/main amd64 libfreerdp-server3-3 amd64 3.5.1+dfsg1-0ubuntu1.4 [143
kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 bsdutils amd64 1:2.39.3-9ubuntu6.5 [96,1 kB]
Des:3 http://security.ubuntu.com/ubuntu noble-security/main amd64 libfreerdp3-3 amd64 3.5.1+dfsg1-0ubuntu1.4 [813 kB]
```

Ilustración 5 - Actualización de paquetes

2. KRNL-5820: Deshabilitar la generación de Core Dumps

Se configuró *hard core 0* en */etc/security/limits.conf* y se ajustó el parámetro *fs.suid_dumpable=0*, para evitar que el sistema genere volcados de memoria tras un fallo, los cuales podrían contener información sensible (como credenciales) accesible para un atacante.

```
GNU nano 7.2 /etc/security/limits.conf
#
# - address space limit (KB)
# - maxlogins - max number of logins for this user
# - maxsyslogins - max number of logins on the system
# - priority - the priority to run user process with
# - locks - max number of file locks the user can hold
# - sigpending - max number of pending signals
# - msgqueue - max memory used by POSIX message queues (bytes)
# - nice - max nice priority allowed to raise to values: [-20, 19]
# - rtprio - max realtime priority
# - chroot - change root to directory (Debian-specific)
#
#<domain> <type> <item> <value>
#
#* soft core 0
#* hard core 100000
#* hard rss 10000
#@student hard nproc 20
#@faculty soft nproc 20
#@faculty hard nproc 50
#ftp hard nproc 0
#ftp - chroot /ftp
#@student - maxlogins 4

* hard core 0

# End of file

Ayuda  Guardar  Buscar  Cortar  Ejecutar  Ubicación  Deshacer  Poner marca
Salir  Leer fich.  Reemplazar  Pegar  Justificar  Ir a línea  Rehacer  Copiar
```

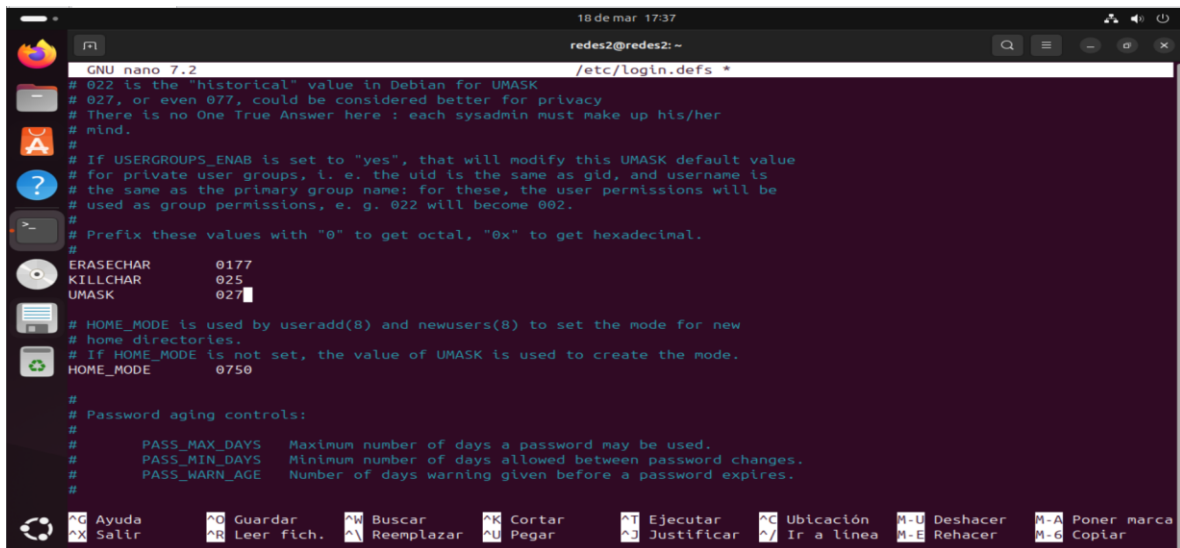
Ilustración 6 - Configuración de Hard Core

```
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$ sudo nano /etc/security/limits.conf
redes2@redes2:~$ sudo sysctl -w fs.suid_dumpable=0
fs.suid_dumpable = 0
```

Ilustración 7 - Ajuste de parámetro

3. AUTH-9328: Restringir el UMASK por defecto

Se cambió el valor a 027 en `/etc/login.defs`. Esto establece que los archivos nuevos creados por usuarios no sean legibles ni modificables por el grupo "otros", siguiendo el principio de menor privilegio.

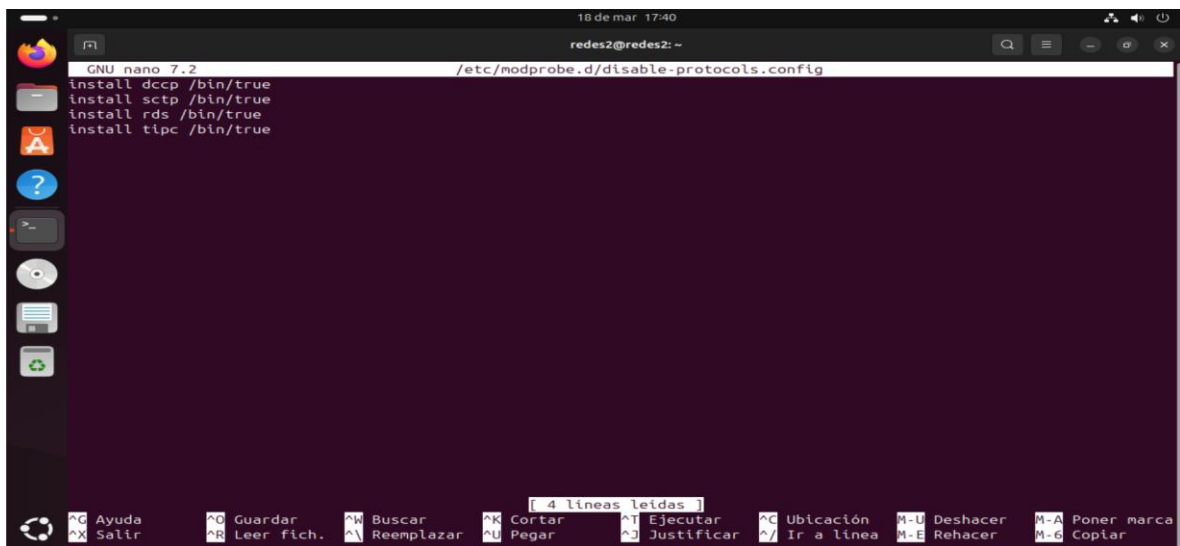


```
GNU nano 7.2 /etc/login.defs *
# 022 is the "historical" value in Debian for UMASK
# 027, or even 077, could be considered better for privacy
# There is no One True Answer here : each sysadmin must make up his/her
# mind.
#
# If USERGROUPS_ENAB is set to "yes", that will modify this UMASK default value
# for private user groups, i. e. the uid is the same as gid, and username is
# the same as the primary group name: for these, the user permissions will be
# used as group permissions, e. g. 022 will become 002.
#
# Prefix these values with "0" to get octal, "0x" to get hexadecimal.
#
ERASECHAR      0177
KILLCHAR       025
UMASK          027
#
# HOME_MODE is used by useradd(8) and newusers(8) to set the mode for new
# home directories.
# If HOME_MODE is not set, the value of UMASK is used to create the mode.
HOME_MODE      0750
#
# Password aging controls:
#
#       PASS_MAX_DAYS   Maximum number of days a password may be used.
#       PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#       PASS_WARN_AGE   Number of days warning given before a password expires.
#
^G Ayuda      ^O Guardar    ^W Buscar     ^K Cortar     ^T Ejecutar   ^C Ubicación  ^U Deshacer   ^A Poner marca
^X Salir      ^R Leer fich. ^N Reemplazar ^L Pegar      ^J Justificar ^_ Ir a línea  ^E Rehacer    ^M Copiar
```

Ilustración 8 - Restricción de UMASK

4. NETW-3200: Deshabilitar protocolos de red obsoletos

Se crearon reglas en `modprobe.d` para deshabilitar protocolos como DCCP y SCTP. Esto reduce la superficie de ataque eliminando controladores de red que no se utilizan pero que suelen tener vulnerabilidades heredadas.



```
GNU nano 7.2 /etc/modprobe.d/disable-protocols.config
install dccp /bin/true
install sctp /bin/true
install rds /bin/true
install tIPC /bin/true
```

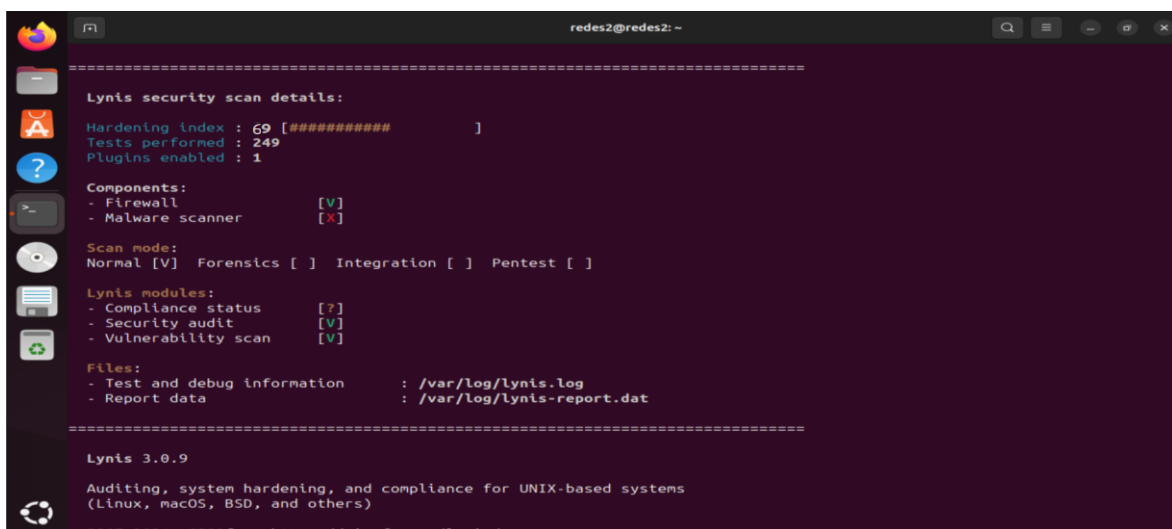
Ilustración 9 - Creación de reglas

5. BANN-7126 / BANN-7130: Configurar Banners Legales

Se configuraron mensajes de advertencia legal en */etc/issue*, ya que, es un requisito legal para notificar a usuarios no autorizados que su actividad está siendo monitoreada, lo cual es vital en procesos de respuesta a incidentes.

```
redes2@redes2:~$  
redes2@redes2:~$ echo "ACCESO RESTRINGIDO. Toda actividad esta siendo monitoreada." | sudo tee /etc/issue /etc/issue.net  
ACCESO RESTRINGIDO. Toda actividad esta siendo monitoreada.  
redes2@redes2:~$  
redes2@redes2:~$  
redes2@redes2:~$
```

Ilustración 10 - Configuración de Banners Legales



```
redes2@redes2: ~  
=====
```

Lynis security scan details:

Hardening Index : 69 [#####]
Tests performed : 249
Plugins enabled : 1

Components:

- Firewall [V]
- Malware scanner [X]

Scan mode:

Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

```
=====
```

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021 - CISOFY - <https://cisofy.com/lynis/>

Se volvió a realizar un escaneo, teniendo un resultado de **69**. Aunque el score no aumentó significativamente, se puede visualizar que la modificación y mejora en los alertamientos del escaneo, sí hace que el score suba.

Laboratorio 2: Hardening de SSH

Objetivo: Asegurar el acceso remoto eliminando vulnerabilidades pre-autenticación y forzando criptografía moderna.

Se generaron llaves elípticas en lugar de RSA, ya que ofrecen mayor seguridad con longitudes de clave más cortas y son más resistentes a ataques de canal lateral.

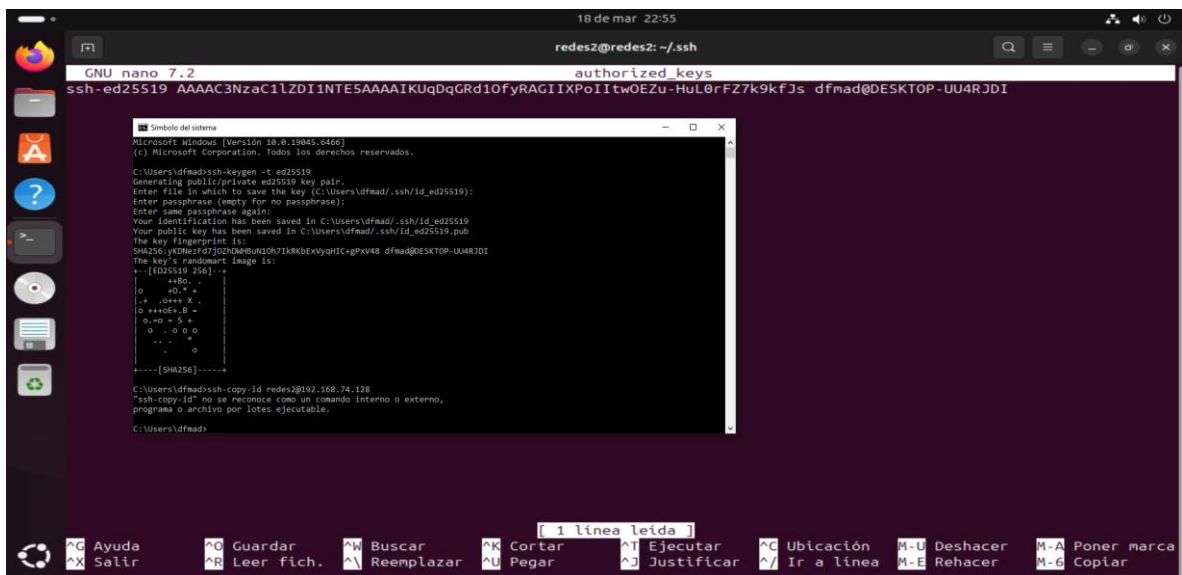


Ilustración 11 - Generación de llaves elípticas

Se configuró el intercambio de claves *mlkem768x25519-sha256* en *sshd_config* porque protege las comunicaciones actuales contra la amenaza de "almacenar ahora, descifrar después" por parte de futuros computadores cuánticos.

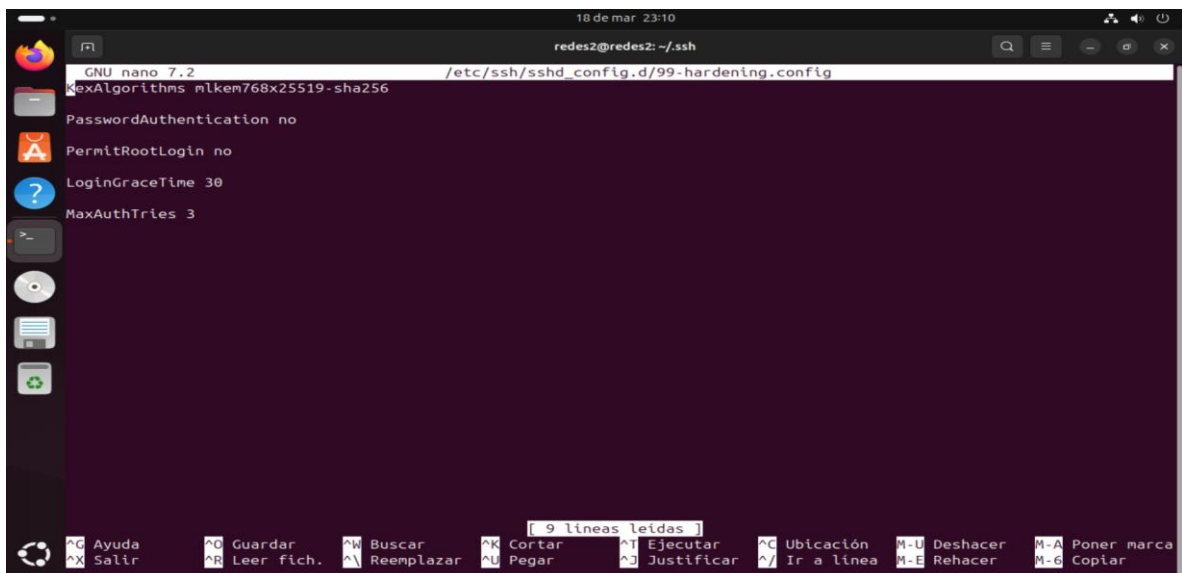


Ilustración 12 - Configuración de intercambio de llaves

Se estableció un *bantime* de 3600 segundos y un máximo de 3 reintentos, para mitigar ataques automatizados de fuerza bruta, bloqueando temporalmente la IP del atacante tras múltiples fallos.

```
redes2@redes2:~/.ssh$ sudo apt install fail2ban -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
python3-pyasyncore python3-pyinotify whois
Paquetes sugeridos:
mailx monit sqlite3 python-pyinotify-doc
Se instalarán los siguientes paquetes NUEVOS:
fail2ban python3-pyasyncore python3-pyinotify whois
0 actualizados, 4 nuevos se instalarán, 0 para eliminar y 11 no actualizados.
Se necesita descargar 496 kB de archivos.
Se utilizarán 2.572 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 python3-pyasyncore all 1.0.2-2 [10,1 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 fail2ban all 1.0.2-3ubuntu0.1 [409 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 python3-pyinotify all 0.9.6-2ubuntu1 [25,0 kB]
Des:4 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 whois amd64 5.5.22 [51,7 kB]
Descargados 496 kB en 2s (287 kB/s)
Seleccionando el paquete python3-pyasyncore previamente no seleccionado.
(Leyendo la base de datos ... 159611 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../python3-pyasyncore_1.0.2-2_all.deb ...
Desempaquetando python3-pyasyncore (1.0.2-2) ...
Seleccionando el paquete fail2ban previamente no seleccionado.
Preparando para desempaquetar .../fail2ban_1.0.2-3ubuntu0.1_all.deb ...
Desempaquetando fail2ban (1.0.2-3ubuntu0.1) ...
Seleccionando el paquete python3-pyinotify previamente no seleccionado.
Preparando para desempaquetar .../python3-pyinotify_0.9.6-2ubuntu1_all.deb ...
Desempaquetando python3-pyinotify (0.9.6-2ubuntu1) ...
Seleccionando el paquete whois previamente no seleccionado.
Preparando para desempaquetar .../whois_5.5.22_amd64.deb ...
Desempaquetando whois (5.5.22) ...
Configurando whois (5.5.22) ...
Configurando python3-pyasyncore (1.0.2-2) ...
```

Ilustración 13 - Instalación de Fail2Ban

```
GNU nano 7.2 /etc/fail2ban/jail.local
# WARNING: heavily refactored in 0.9.0 release. Please review and
# customize settings for your setup.
#
# Changes: In most of the cases you should not modify this
# file, but provide customizations in jail.local file,
# or separate .conf files under jail.d/ directory, e.g.:
#
# HOW TO ACTIVATE JAILS:
#
# YOU SHOULD NOT MODIFY THIS FILE.
#
# It will probably be overwritten or improved in a distribution update.
#
# Provide customizations in a jail.local file or a jail.d/customisation.local.
# For example to change the default bantime for all jails and to enable the
# ssh-iptables jail the following (uncommented) would appear in the .local file.
# See man 5 jail.conf for details.
#
# [DEFAULT]
# bantime = 1h
#
# [sshd]
enabled = true
maxretry = 3
bantime = 3600
#
# See jail.conf(5) man page for more information
```

Ilustración 14 - Establecimiento de bantime

Laboratorio 3: Firewall con nftables

Objetivo: Construir una política de firewall nativa que reemplace a iptables

Se utilizó la familia *inet* para gestionar IPv4 e IPv6 en una misma tabla. Se implementó un conjunto de IPs bloqueadas y un límite de tasa de 4 conexiones por minuto para SSH.

El límite de tasa previene la saturación del servicio SSH y dificulta el escaneo de puertos agresivo


```
19 de mar 09:46
redes2@redes2: ~
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$ sudo apt install openscap-scanner ssg-base ssg-debderived -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
liblua5.3-0 libopendbx1-sqlite3 libopendbx1t64 libopenscap25t64 librpm9t64 librpmio9t64 libxmlsec1t64
libxmlsec1t64-openssl openscap-common rpm-common
Paquetes sugeridos:
openscap-doc ansible puppet
Se instalarán los siguientes paquetes NUEVOS:
liblua5.3-0 libopendbx1-sqlite3 libopendbx1t64 libopenscap25t64 librpm9t64 librpmio9t64 libxmlsec1t64
libxmlsec1t64-openssl openscap-common openscap-scanner rpm-common ssg-base ssg-debderived
0 actualizados, 13 nuevos se instalarán, 0 para eliminar y 12 no actualizados.
Se necesita descargar 6.149 kB de archivos.
Se utilizarán 238 MB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 liblua5.3-0 amd64 5.3.6-2build2 [143 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 libopendbx1t64 amd64 1.4.6-17 [27,2 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 libopendbx1-sqlite3 amd64 1.4.6-17 [5.348 B]
Des:4 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 librpmio9t64 amd64 4.18.2+dfsg-2.1build2 [95,2 kB]
Des:5 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 librpm9t64 amd64 4.18.2+dfsg-2.1build2 [217 kB]
Des:6 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 libxmlsec1t64 amd64 1.2.39-5build2 [153 kB]
Des:7 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 libxmlsec1t64-openssl amd64 1.2.39-5build2 [84,1 kB]
Des:8 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 libopenscap25t64 amd64 1.3.9+dfsg-1.1ubuntu2 [507 kB]
Des:9 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 openscap-common all 1.3.9+dfsg-1.1ubuntu2 [1.315 kB]
Des:10 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 openscap-scanner amd64 1.3.9+dfsg-1.1ubuntu2 [51,3 kB]
Des:11 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 rpm-common amd64 4.18.2+dfsg-2.1build2 [34,0 kB]
Des:12 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 ssg-base all 0.1.71-1 [29,4 kB]
Des:13 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 ssg-debderived all 0.1.71-1 [3.488 kB]
Descargados 6.149 kB en 2s (3.768 kB/s)
Seleccionando el paquete liblua5.3-0:amd64 previamente no seleccionado.
```

Ilustración 17 - Instalación de OpenScap

```
19 de mar 09:53
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$ oscap xccdf eval --profile xccdf_org.ssgproject.content_profile_cis_level1_server --report reporte_cis_lab4.html /usr/share/xml/scap/ssg/content/ssg-ubuntu2204-ds.xml
--- Starting Evaluation ---

Title    Package "prelink" Must not be Installed
Rule     xccdf_org.ssgproject.content_rule_package_prelink_removed
Result   notapplicable

Title    Install AIDE
Rule     xccdf_org.ssgproject.content_rule_package_aide_installed
Result   notapplicable

Title    Build and Test AIDE Database
Rule     xccdf_org.ssgproject.content_rule_aide_build_database
Result   notapplicable

Title    Configure AIDE to Verify the Audit Tools
Rule     xccdf_org.ssgproject.content_rule_aide_check_audit_tools
Result   notapplicable

Title    Configure Periodic Execution of AIDE
Rule     xccdf_org.ssgproject.content_rule_aide_periodic_cron_checking
Result   notapplicable

Title    Ensure /tmp Located On Separate Partition
Rule     xccdf_org.ssgproject.content_rule_partition_for_tmp
Result   notapplicable

Title    Disable the GNOME3 Login User List
Rule     xccdf_org.ssgproject.content_rule_disable_gnome_disable_user_list
```

Ilustración 18 - Ejecución de la auditoria

Do not attempt to implement any of the settings in this guide without first testing them in a non-operational environment. The creators of this guidance assume no responsibility whatsoever for its use by other parties, and makes no guarantees, expressed or implied, about its quality, reliability, or any other characteristic.

Evaluation Characteristics

Evaluation target	redes2
Benchmark URL	#scap_org.open-scap_comp_ssg-ubuntu2204-xccdf.xml
Benchmark ID	xccdf_org.ssgproject.content_benchmark_UBUNTU_22-04
Benchmark version	0.1.71
Profile ID	xccdf_org.ssgproject.content_profile_cis_level1_server
Started at	2026-03-19T10:11:53-06:00
Finished at	2026-03-19T10:11:53-06:00
Performed by	redes2
Test system	cpe:/a:redhat:openscap:1.3.9

CPE Platforms

- cpe:/o:canonical:ubuntu_linux:22.04:-lts

Addresses

- IPv4 127.0.0.1
- IPv4 192.168.74.128
- IPv6 0:0:0:0:0:0:1
- IPv6 fe80:0:0:0:20c:29ff:fe4c:f878
- MAC 00:00:00:00:00:00
- MAC 00:0C:29:4C:F8:78

Compliance and Scoring

There were no failed or uncertain rules. It seems that no action is necessary.

Ilustración 19 - Reporte de resultados

Permisos de archivos de identidad (CIS 6.1.1-6.1.3): Se ajustaron el dueño y permisos de /etc/shadow a 640. Impide que usuarios sin privilegios lean los hashes de las contraseñas.

```
redes2@redes2:~$ sudo chown root:root /etc/passwd /etc/shadow /etc/group
redes2@redes2:~$ sudo chmod 644 /etc/passwd
redes2@redes2:~$ sudo chmod 640 /etc/shadow
redes2@redes2:~$ sudo chmod 644 /etc/group
redes2@redes2:~$
```

Ilustración 20 - CIS 6.1.1-6.1.3

Hardening SSH (CIS 5.2.6): Deshabilitación de X11Forwarding. Evita ataques de secuestro de sesión gráfica.

```
redes2@redes2:~$ sudo sed -i 's/^X11Forwarding yes/X11Forwarding no/' /etc/ssh/sshd_config
redes2@redes2:~$ echo "MaxStartups 10:30:100" | sudo tee -a /etc/ssh/sshd_config.d/99-hardening.conf
MaxStartups 10:30:100
redes2@redes2:~$ sudo systemctl restart ssh
redes2@redes2:~$
```

Ilustración 21 - CIS 5.2.6

Fuga de Datos por Volcados de Memoria CIS 1.5.1

```
redes2@redes2:~$ sudo systemctl disable apport.service
Synchronizing state of apport.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install disable apport
Removed "/etc/systemd/system/multi-user.target.wants/apport.service".
redes2@redes2:~$ sudo systemctl mask apport.service
Created symlink /etc/systemd/system/apport.service → /dev/null.
redes2@redes2:~$
```

Prevención de exploits USB (CIS 1.1.1.1 – 1.1.1.4): Deshabilitación de los sistemas de archivos cramfs, udf y jffs2. Evita la ejecución de código malicioso mediante dispositivos de almacenamiento físico no autorizados.

```

redes2@redes2:~$ echo "install cramfs /bin/true" | sudo tee /etc/modprobe.d/cis_fs.conf
install cramfs /bin/true
redes2@redes2:~$ echo "install freevxfs /bin/true" | sudo tee -a /etc/modprobe.d/cis_fs.conf
install freevxfs /bin/true
redes2@redes2:~$ echo "install jffs2 /bin/true" | sudo tee -a /etc/modprobe.d/cis_fs.conf
install jffs2 /bin/true
redes2@redes2:~$ echo "install udf /bin/true" | sudo tee -a /etc/modprobe.d/cis_fs.conf
install udf /bin/true
redes2@redes2:~$ sudo rmmod cramfs freevxfs jffs2 udf 2>/dev/null
redes2@redes2:~$

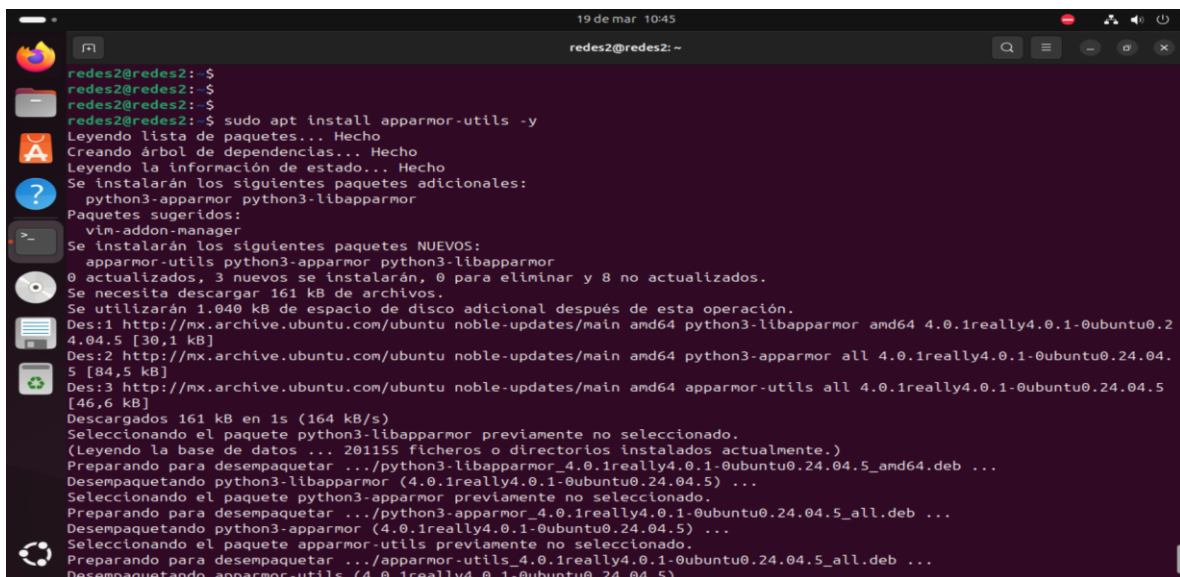
```

Ilustración 22 - CIS 1.1.1.1 a 1.1.1.4

Laboratorio 5: Control de Acceso Obligatorio (AppArmor)

Objetivo: Limitar el comportamiento de una aplicación mediante perfiles restrictivos.

Se instaló AppArmor y se creó un script que intentaba leer `/etc/shadow` y escribir en `/tmp`.



```

redes2@redes2:~$ sudo apt install apparmor-utils -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
python3-apparmor python3-libapparmor
Paquetes sugeridos:
vim-addon-manager
Se instalarán los siguientes paquetes NUEVOS:
apparmor-utils python3-apparmor python3-libapparmor
0 actualizados, 3 nuevos se instalarán, 0 para eliminar y 8 no actualizados.
Se necesita descargar 161 kB de archivos.
Se utilizarán 1.040 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 python3-libapparmor amd64 4.0.1really4.0.1-0ubuntu0.24.04.5 [30,1 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 python3-apparmor all 4.0.1really4.0.1-0ubuntu0.24.04.5 [84,5 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 apparmor-utils all 4.0.1really4.0.1-0ubuntu0.24.04.5 [46,6 kB]
Descargados 161 kB en 1s (164 kB/s)
Seleccionando el paquete python3-libapparmor previamente no seleccionado.
(Leyendo la base de datos ... 201155 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../python3-libapparmor_4.0.1really4.0.1-0ubuntu0.24.04.5_amd64.deb ...
Desempaquetando python3-libapparmor (4.0.1really4.0.1-0ubuntu0.24.04.5) ...
Seleccionando el paquete python3-apparmor previamente no seleccionado.
Preparando para desempaquetar .../python3-apparmor_4.0.1really4.0.1-0ubuntu0.24.04.5_all.deb ...
Desempaquetando python3-apparmor (4.0.1really4.0.1-0ubuntu0.24.04.5) ...
Seleccionando el paquete apparmor-utils previamente no seleccionado.
Preparando para desempaquetar .../apparmor-utils_4.0.1really4.0.1-0ubuntu0.24.04.5_all.deb ...
Desempaquetando apparmor-utils (4.0.1really4.0.1-0ubuntu0.24.04.5) ...

```

Ilustración 23 - Instalación de AppArmor

Z

```

redes2@redes2:~$
redes2@redes2:~$ cat << 'EOF' > ~/app_prueba.sh
> #!/bin/bash
> echo "--- Iniciando aplicacion ---"
> cat /etc/shadow 2>/dev/null && echo "[+] Exito leyendo contraseñas" || echo "[-] Acceso denegado a shadow"
> touch /tmp/prueba_apparmor.txt && echo "[+] Exito escribiendo en /tmp" || echo "[-] Falla escribiendo en /tmp"
> EOF
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$

```

Ilustración 24 - Script malicioso


```

redes2@redes2:~$ sudo nano /etc/apparmor.d/home.redes2.app_prueba.sh
redes2@redes2:~$
redes2@redes2:~$
redes2@redes2:~$ sudo apparmor_parser -r /etc/apparmor.d/home.redes2.app_prueba.sh
redes2@redes2:~$ sudo aa-enforce /home/redes2/app_prueba.sh
Estableciendo /home/redes2/app_prueba.sh al modo forzar.
redes2@redes2:~$ sudo ~/app_prueba.sh
/bin/bash: /home/redes2/app_prueba.sh: Permiso denegado
redes2@redes2:~$

```

Ilustración 25 - Ejecución de prueba

Se configuró el perfil para denegar específicamente la lectura de archivos de identidad (deny /etc/shadow r). AppArmor actúa como una última línea de defensa; si un atacante logra ejecutar código, el perfil impide que acceda a archivos sensibles fuera de su alcance permitido.

```

GNU nano 7.2 /etc/apparmor.d/home.redes2.app
# Last Modified: Thu Mar 19 10:58:34 2026
abi <abi/3.0>,

#include <tunables/global>

/home/redes2/app_prueba.sh {
    #include <abstractions/base>
    #include <abstractions/bash>

    /usr/bin/bash rix,
    /usr/bin/cat rix,
    /usr/bin/touch rix,

    #Permitir lectura/escritura en su propio directorio y /tmp
    /home/redes2/app_prueba.sh r,
    /tmp/prueba_apparmor.txt rw,

    #Denegar explícitamente el acceso a shadow
    deny /etc/shadow r,
}

```

Ilustración 26 - Configuración de perfil

Laboratorio 6: Monitoreo de Integridad (AIDE)

Objetivo: Detectar cambios no autorizados en archivos críticos.

Se instaló y creó la base de datos de firmas criptográficas inicial (*aideinit*).

```
redes2@redes2:~$ sudo apt install aide -y
[sudo] contraseña para redes2:
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
aide-common bsd-mailx liblockfile-bin liblockfile1 libmhash2 libnsl2 postfix
Paquetes sugeridos:
figlet postfix-cdb postfix-doc postfix-ldap postfix-lmdb postfix-mta-sts-resolver postfix-mysql postfix-pcre
postfix-pgsql postfix-sqlite procmail sasl2-bin | dovecot-common
Se instalarán los siguientes paquetes NUEVOS:
aide aide-common bsd-mailx liblockfile-bin liblockfile1 libmhash2 libnsl2 postfix
0 actualizados, 8 nuevos se instalarán, 0 para eliminar y 8 no actualizados.
Se necesita descargar 1.676 kB de archivos.
Se utilizarán 5.506 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 libnsl2 amd64 1.3.0-3build3 [41,4 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 postfix amd64 3.8.6-1build2 [1.254 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 libmhash2 amd64 0.9.9-9build3 [94,2 kB]
Des:4 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 aide amd64 0.18.6-2ubuntu0.1 [118 kB]
Des:5 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 liblockfile-bin amd64 1.17-1build3 [11,2 kB]
Des:6 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 liblockfile1 amd64 1.17-1build3 [6.840 B]
Des:7 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 aide-common all 0.18.6-2ubuntu0.1 [82,2 kB]
Des:8 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 bsd-mailx amd64 8.1.2-0.20220412cvs-1build1 [67,2 kB]
Descargados 1.676 kB en 3s (657 kB/s)
```

Ilustración 27 - Instalación de AIDE

```
redes2@redes2:~$ sudo aideinit
[sudo] contraseña para redes2:
Overwrite existing /var/lib/aide/aide.db.new [Yn]? y
Running aide --init...
redes2@redes2:~$
```

Ilustración 28 - Inicialización de AIDE

```
redes2@redes2:~$ sudo cp /var/lib/aide/aide.db.new /var/lib/aide/aide.db
[sudo] contraseña para redes2:
redes2@redes2:~$
```

Ilustración 29 - Creación de la Base de Datos

Se modificó `/etc/hosts` y se ejecutó `aide --check`. Permite identificar si un atacante o rootkit ha modificado archivos de configuración del sistema que normalmente no deberían cambiar.

```
redes2@redes2:~$ echo "# Intrusión detectada" | sudo tee -a /etc/hosts
# Intrusión detectada
redes2@redes2:~$
```

Ilustración 30 - Prueba

```

redes2@redes2:~$ sudo aide --config /etc/aide/aide.conf --check
WARNING: get_file_status: lstat() failed for /run/user/1000/gvfs: Permission denied
WARNING: get_file_status: lstat() failed for /run/user/1000/doc: Permission denied
WARNING: hash calculation: '/home/redes2/.local/share/gnome-shell/application_state' has been changed (changed attribute
s: s+c+m+l, hash could not be calculated)
WARNING: hash calculation: '/run/NetworkManager/devices/2' has been changed (changed attributes: c+m+l, hash could not b
e calculated)
WARNING: hash calculation: '/var/lib/NetworkManager/internal-14f59568-5076-387a-aef6-10adfcca2e26-ens33.lease' has been
changed (changed attributes: c+m, hash could not be calculated)
WARNING: hash calculation: '/var/log/sysstat/sa19' has been changed (changed attributes: s+c+m+b, hash could not be calc
ulated)
Entry /home/redes2/.local/share/gnome-shell/application_state in databases has different attributes: -md5-sha1-rmd160-ti
ger-crc32-haval-gost-crc32b-sha256-sha512-whirlpool
Entry /home/redes2/.local/share/gvfs-metadata/root in databases has different attributes: +md5+sha1+rmd160+tiger+crc32+h
aval+gost+crc32b+sha256+sha512+whirlpool
Entry /run/NetworkManager/devices/2 in databases has different attributes: -md5-sha1-rmd160-tiger-crc32-haval-gost-crc32
b-sha256-sha512-whirlpool
Entry /var/lib/NetworkManager/internal-14f59568-5076-387a-aef6-10adfcca2e26-ens33.lease in databases has different attributes: +md5+sha1+rmd160+tiger+crc32+haval+gost+crc32b+sh
a256+sha512+whirlpool
Entry /var/log/sysstat/sa19 in databases has different attributes: +md5+sha1+rmd160+tiger+crc32+haval+gost+crc32b+sh
a256+sha512+whirlpool
Entry /var/log/aide/aideinit.errors in databases has different attributes: +md5+sha1+rmd160+tiger+crc32+haval+gost+crc32

```

Ilustración 31 - Validación de la prueba

```

-----
Changed entries:
-----
f >.... mc..H.. . : /etc/hosts

```

Ilustración 32 - Validación de la dirección modificada

Laboratorio 7: Seguridad de Contenedores con Podman

Objetivo: Ejecutar contenedores aislados y analizar su cadena de suministro.

Se instaló Podman y se ejecutó una imagen de Alpine sin privilegios de root. Si el contenedor es comprometido, el atacante no obtiene privilegios administrativos sobre el host principal.

```

20 de mar 22:33
redes2@redes2:~$ sudo apt install podman -y
[sudo] contraseña para redes2:
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
  aardvark-dns buildah catatonit common containernetworking-plugins crun fuse-overlayfs
  golang-github-containers-common golang-github-containers-image libslirp0 libsubid4 libyajl2 netavark passt
  slirp4netns uidmap
Paquetes sugeridos:
  containers-storage libwasmmedge0 docker-compose
Se instalarán los siguientes paquetes NUEVOS:
  aardvark-dns buildah catatonit common containernetworking-plugins crun fuse-overlayfs
  golang-github-containers-common golang-github-containers-image libslirp0 libsubid4 libyajl2 netavark passt podman
  slirp4netns uidmap
0 actualizados, 17 nuevos se instalarán, 0 para eliminar y 8 no actualizados.
Se necesita descargar 32,5 MB de archivos.
Se utilizarán 131 MB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 netavark amd64 1.4.0-4 [1.666 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 aardvark-dns amd64 1.4.0-5 [881 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 libsubid4 amd64 1:4.13+dfsg1-4ubuntu3.2 [23,4 kB]
Des:4 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 uidmap amd64 1:4.13+dfsg1-4ubuntu3.2 [26,0 kB]
Des:5 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 containernetworking-plugins amd64 1.1.1+ds1-3ubun
tu0.24.04.3 [7.203 kB]
Des:6 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 golang-github-containers-image all 5.29.2-2 [33,4 kB]
Des:7 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 golang-github-containers-common all 0.57.4+ds1-2u
buntu0.2 [39,9 kB]
Des:8 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 buildah amd64 1.33.7+ds1-1ubuntu0.24.04.3 [8.148
kB]
Des:9 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 catatonit amd64 0.1.7-1 [307 kB]
Des:10 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 common amd64 2.1.10+ds1-1build2 [35,2 kB]
Des:11 http://mx.archive.ubuntu.com/ubuntu noble/main amd64 libyajl2 amd64 2.1.0-5build1 [20,2 kB]
Des:12 http://mx.archive.ubuntu.com/ubuntu noble/universe amd64 crun amd64 1.14.1-1 [406 kB]

```

Ilustración 33 - Instalación de Podman


```
redes2@redes2:~$ podman pull alpine
Resolved "alpine" as an alias (/etc/containers/registries.conf.d/shortnames.conf)
Trying to pull docker.io/library/alpine:latest...
Getting image source signatures
Copying blob 589002ba0eae done |
Copying config a40c03cbb8 done |
Writing manifest to image destination
a40c03cbb81c59bfb0e0887ab0b1859727075da7b9cc576a1cec2c771f38c5fb
redes2@redes2:~$
```

Ilustración 34 - Imagen de Alpine

Se generó un inventario (SBOM) con Syft y se detectaron vulnerabilidades críticas en zlib con Trivy.

```
redes2@redes2:~$ curl -sSL https://raw.githubusercontent.com/anchore/syft/main/install.sh | sudo sh -s -- -b /usr/local
/bin
[info] checking github for the current release tag
[info] fetching release script for tag='v1.42.3'
[info] checking github for the current release tag
[info] using release tag='v1.42.3' version='1.42.3' os='linux' arch='amd64'
[info] installed /usr/local/bin/syft
redes2@redes2:~$
```

Ilustración 35 - Instalación de Syft

```
redes2@redes2:~$ sudo apt install wget apt-transport-https gnupg lsb-release -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
wget ya está en su versión más reciente (1.21.4-1ubuntu4.1).
fijado wget como instalado manualmente.
gnupg ya está en su versión más reciente (2.4.4-2ubuntu17.4).
fijado gnupg como instalado manualmente.
lsb-release ya está en su versión más reciente (12.0-2).
fijado lsb-release como instalado manualmente.
Se instalarán los siguientes paquetes NUEVOS:
  apt-transport-https
0 actualizados, 1 nuevos se instalarán, 0 para eliminar y 19 no actualizados.
Se necesita descargar 3.970 B de archivos.
Se utilizarán 36,9 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 apt-transport-https all 2.8.3 [3.970 B]
Descargados 3.970 B en 1s (7.586 B/s)
Seleccionando el paquete apt-transport-https previamente no seleccionado.
(Leyendo la base de datos ... 202285 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../apt-transport-https_2.8.3_all.deb ...
Desempaquetando apt-transport-https (2.8.3) ...
Configurando apt-transport-https (2.8.3) ...
redes2@redes2:~$
```

Ilustración 36 - Instalación de Trivy

```
redes2@redes2:~$ trivy image alpine
2026-03-20T22:59:52-06:00 INFO Need to update DB
2026-03-20T22:59:52-06:00 INFO Downloading DB... repository="ghcr.io/aquasecurity/trivy-db:2"
88.14 MiB / 88.14 MiB [-----] 100.00% 4.69 MiB p/s 19s
2026-03-20T23:00:12-06:00 INFO Vulnerability scanning is enabled
2026-03-20T23:00:12-06:00 INFO Secret scanning is enabled
2026-03-20T23:00:12-06:00 INFO If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-03-20T23:00:12-06:00 INFO Please see also https://aquasecurity.github.io/trivy/v0.52/docs/scanner/secret/#
recommendation for faster secret detection
2026-03-20T23:00:15-06:00 INFO Detected OS family="alpine" version="3.23.3"
2026-03-20T23:00:15-06:00 WARN This OS version is not on the EOL list family="alpine" version="3.23"
2026-03-20T23:00:15-06:00 INFO [alpine] Detecting vulnerabilities... os_version="3.23" repository="3.23" pkg_
num=16
2026-03-20T23:00:15-06:00 INFO Number of language-specific files num=0

alpine (alpine 3.23.3)
Total: 2 (UNKNOWN: 0, LOW: 0, MEDIUM: 1, HIGH: 1, CRITICAL: 0)

+-----+-----+-----+-----+-----+-----+-----+
| Library | Vulnerability | Severity | Status | Installed Version | Fixed Version | Title |
+-----+-----+-----+-----+-----+-----+-----+
| zlib | CVE-2026-22184 | HIGH | fixed | 1.3.1-r2 | 1.3.2-r0 | zlib: zlib: Arbitrary code executio |
| n via buffer overflow in | | | | | | untgz utility |
| 22184 | | | | | | https://avd.aquasec.com/nvd/cve-202 |
+-----+-----+-----+-----+-----+-----+-----+
```

Ilustración 37 - Escaneo de Trivy

Total: 2 (UNKNOWN: 0, LOW: 0, MEDIUM: 1, HIGH: 1, CRITICAL: 0)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
zlib	CVE-2026-22184	HIGH	fixed	1.3.1-r2	1.3.2-r0	zlib: zlib: Arbitrary code executio
	n via buffer overflow in					untgz utility
CVE-2026-22184						https://avd.aquasec.com/nvd/cve-2026-22184
	CVE-2026-27171	MEDIUM				zlib: zlib: Denial of Service via i
	nfinite loop in CRC32					combine functions...
CVE-2026-27171						https://avd.aquasec.com/nvd/cve-2026-27171

redes2@redes2:~\$

Ilustración 38 - Resultados

Laboratorio 8: Sandboxing con systemd

Objetivo: Reducir la exposición de servicios individuales.

Se instaló y ejecutó nginx. Nginx inició con un puntaje de 9.6 (UNSAFE).

```
redes2@redes2:~$ sudo apt update || true && sudo apt install nginx -y
Obj:1 http://mx.archive.ubuntu.com/ubuntu noble InRelease
Obj:2 http://mx.archive.ubuntu.com/ubuntu noble-updates InRelease
Des:3 https://aquasecurity.github.io/trivy-repo/deb noble InRelease [3.061 B]
Obj:4 http://security.ubuntu.com/ubuntu noble-security InRelease
Obj:5 http://mx.archive.ubuntu.com/ubuntu noble-backports InRelease
Err:3 https://aquasecurity.github.io/trivy-repo/deb noble InRelease
  Las firmas siguientes no se pudieron verificar porque su clave pública no está disponible: NO_PUBKEY E9D0A3616276FA6C
Leyendo lista de paquetes... Hecho
W: Error de GPG: https://aquasecurity.github.io/trivy-repo/deb noble InRelease: Las firmas siguientes no se pudieron ver
ificar porque su clave pública no está disponible: NO_PUBKEY E9D0A3616276FA6C
E: El repositorio «https://aquasecurity.github.io/trivy-repo/deb noble InRelease» no está firmado.
N: No se puede actualizar de un repositorio como este de forma segura y por tanto está deshabilitado por omisión.
N: Vea la página de manual apt-secure(8) para los detalles sobre la creación de repositorios y la configuración de usar
los.
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
  nginx-common
Paquetes sugeridos:
  fcgiwrap nginx-doc
Se instalarán los siguientes paquetes NUEVOS:
  nginx nginx-common
0 actualizados, 2 nuevos se instalarán, 0 para eliminar y 16 no actualizados.
Se necesita descargar 565 kB de archivos.
Se utilizarán 1.596 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 nginx-common all 1.24.0-2ubuntu7.6 [43,5 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 nginx amd64 1.24.0-2ubuntu7.6 [521 kB]
Descargados 565 kB en 1s (616 kB/s)
Preconfigurando paquetes ...
Seleccionando el paquete nginx-common previamente no seleccionado.
```

Ilustración 39 - Instalación de NGINX


```

✓ CapabilityBoundingSet=-CAP_SYS_RAWIO      Service has no raw I/O access
✓ ProtectHome=                             Service has no access to home directories
✓ PrivateDevices=                           Service has no access to hardware devices
✓ CapabilityBoundingSet=-CAP_NET_ADMIN      Service has network configuration privileges
✓ ProtectProc=                             Service has full access to process tree (/proc hidepid=)
✓ ProcSubset=                              Service has full access to non-process /proc files (/proc)
✓ CapabilityBoundingSet=-CAP_NET_(BIND_SERVICE|BROADCAST|RAW) Service has elevated networking privileges
✓ CapabilityBoundingSet=-CAP_AUDIT_*        Service has audit subsystem access
✓ CapabilityBoundingSet=-CAP_SYS_ADMIN      Service has administrator privileges
✓ PrivateNetwork=                           Service has access to the host's network
✓ PrivateUsers=                             Service has access to other users
✓ PrivateTmp=                               Service has access to other software's temporary files
✓ CapabilityBoundingSet=-CAP_SYSLOG         Service has access to kernel logging
✓ DeviceAllow=                              Service has a minimal device ACL
✓ KeyringMode=                             Service doesn't share key material with other services
✓ Delegates=                               Service does not maintain its own delegated control group
✓ SystemCallFilter=-@clock                 Service does not filter system calls
✓ SystemCallFilter=-@cpu-emulation         Service does not filter system calls

```

Ilustración 43 - Validación de directivas aplicadas

```

✓ CapabilityBoundingSet=-CAP_NET_ADMIN      Service has network configuration privileges
✓ ProtectProc=                             Service has full access to process tree (/proc hidepid=)
✓ ProcSubset=                              Service has full access to non-process /proc files (/proc)
✓ CapabilityBoundingSet=-CAP_NET_(BIND_SERVICE|BROADCAST|RAW) Service has elevated networking privileges
✓ CapabilityBoundingSet=-CAP_AUDIT_*        Service has audit subsystem access
✓ CapabilityBoundingSet=-CAP_SYS_ADMIN      Service has administrator privileges
✓ PrivateNetwork=                           Service has access to the host's network
✓ PrivateUsers=                             Service has access to other users
✓ PrivateTmp=                               Service has access to other software's temporary files
✓ CapabilityBoundingSet=-CAP_SYSLOG         Service has access to kernel logging
✓ DeviceAllow=                              Service has a minimal device ACL
✓ KeyringMode=                             Service doesn't share key material with other services
✓ Delegates=                               Service does not maintain its own delegated control group
✓ SystemCallFilter=-@clock                 Service does not filter system calls
✓ SystemCallFilter=-@cpu-emulation         Service does not filter system calls
✓ SystemCallFilter=-@debug                 Service does not filter system calls
✓ SystemCallFilter=-@module                Service does not filter system calls
✓ SystemCallFilter=-@mount                 Service does not filter system calls
✓ SystemCallFilter=-@obsolete              Service does not filter system calls
✓ SystemCallFilter=-@privileged            Service does not filter system calls
✓ SystemCallFilter=-@raw-io                Service does not filter system calls
✓ SystemCallFilter=-@reboot                 Service does not filter system calls
✓ SystemCallFilter=-@resources              Service does not filter system calls
✓ SystemCallFilter=-@swap                   Service does not filter system calls
✓ IPAddressDeny=                           Service does not define an IP address allow list
✓ NotifyAccess=                             Service child processes cannot alter service state
✓ PrivateMounts=                           Service cannot install system mounts
✓ CapabilityBoundingSet=-CAP_MKNOD          Service cannot create device nodes
✓ UMask=                                   Files created by service are world-readable by default

→ Overall exposure level for nginx.service: 8.3 EXPOSED 🟡
lines 54-84/84 (END)

```

Ilustración 44 - Validación de directivas aplicadas 2

Laboratorio 9: Hardening de Parámetros del Kernel

Objetivo: Configurar y verificar parámetros críticos del núcleo para protección contra exploits y endurecimiento de la red.

Se creó el archivo de configuración persistente `/etc/sysctl.d/99-hardening.conf` utilizando el editor `nano`.

Se ingresaron los parámetros de seguridad recomendados para un entorno moderno

```
GNU nano 7.2 /etc/sysctl.d/99-hardening.conf *
kernel.io_uring_disabled = 2

net.ipv4.tcp_syncookies = 1

kernel.kptr_restrict = 2

kernel.dmesg_restrict = 1

kernel.randomize_va_space = 2
```

Ilustración 45 - Archivo de configuración

Se aplicaron los cambios de forma inmediata y global en el sistema mediante el comando `sudo sysctl --system`.

```
redes2@redes2:~$ sudo sysctl --system
* Aplicando /usr/lib/sysctl.d/10-apparmor.conf...
* Aplicando /etc/sysctl.d/10-bufferbloat.conf...
* Aplicando /etc/sysctl.d/10-console-messages.conf...
* Aplicando /etc/sysctl.d/10-ipv6-privacy.conf...
* Aplicando /etc/sysctl.d/10-kernel-hardening.conf...
* Aplicando /etc/sysctl.d/10-magic-sysrq.conf...
* Aplicando /etc/sysctl.d/10-map-count.conf...
* Aplicando /etc/sysctl.d/10-network-security.conf...
* Aplicando /etc/sysctl.d/10-ptrace.conf...
* Aplicando /etc/sysctl.d/10-zeropage.conf...
* Aplicando /usr/lib/sysctl.d/30-tracker.conf...
* Aplicando /usr/lib/sysctl.d/50-bubblewrap.conf...
* Aplicando /usr/lib/sysctl.d/50-pid-max.conf...
* Aplicando /etc/sysctl.d/99-hardening.conf...
* Aplicando /usr/lib/sysctl.d/99-protect-links.conf...
* Aplicando /etc/sysctl.d/99-sysctl.conf...
* Aplicando /etc/sysctl.conf...
kernel.apparmor_restrict_unprivileged_userns = 1
net.core.default_qdisc = fq_codel
kernel.printk = 4 4 1 7
net.ipv6.conf.all.use_tempaddr = 2
net.ipv6.conf.default.use_tempaddr = 2
kernel.kptr_restrict = 1
kernel.sysrq = 176
vm.max_map_count = 1048576
net.ipv4.conf.default.rp_filter = 2
net.ipv4.conf.all.rp_filter = 2
kernel.yama.ptrace_scope = 1
vm.mmap_min_addr = 65536
fs.inotify.max_user_watches = 65536
```

Ilustración 46 - Aplicación de cambios

Parámetro	Comando de verificación	Resultado esperado	¿Qué protege?
io_uring	<code>sysctl kernel.io_uring_disabled</code>	2	Bloquea la superficie de ataque más explotada en 2025.
ASLR	<code>sysctl kernel.randomize_va_space</code>	2	Dificulta que un exploit sepa dónde están las funciones en memoria.
dmesg	<code>sysctl kernel.dmesg_restrict</code>	1	Impide que usuarios normales vean logs sensibles del hardware.
SYN Cookies	<code>sysctl net.ipv4.tcp_syncookies</code>	1	Protege el stack de red contra saturación de conexiones falsas.

Laboratorio 10: Logs de Auditoría (auditd)

Objetivo: Registrar eventos críticos de seguridad de forma inmutable.

Instalación de *auditd* y configuración de reglas para vigilar archivos de identidad, escalación de privilegios y ejecución de comandos.

```
redes2@redes2:~$ sudo apt update || true && sudo apt install auditd audispd-plugins -y
Des:1 https://aquasecurity.github.io/trivy-repo/deb noble InRelease [3.061 B]
Obj:2 http://mx.archive.ubuntu.com/ubuntu noble InRelease
Err:1 https://aquasecurity.github.io/trivy-repo/deb noble InRelease
  Las firmas siguientes no se pudieron verificar porque su clave pública no está disponible: NO_PUBKEY E9D0A3616276FA6C
Obj:3 http://security.ubuntu.com/ubuntu noble-security InRelease
Obj:4 http://mx.archive.ubuntu.com/ubuntu noble-updates InRelease
Obj:5 http://mx.archive.ubuntu.com/ubuntu noble-backports InRelease
Leyendo lista de paquetes... Hecho
W: Error de GPG: https://aquasecurity.github.io/trivy-repo/deb noble InRelease: Las firmas siguientes no se pudieron ver
ificar porque su clave pública no está disponible: NO_PUBKEY E9D0A3616276FA6C
E: El repositorio «https://aquasecurity.github.io/trivy-repo/deb noble InRelease» no está firmado.
N: No se puede actualizar de un repositorio como este de forma segura y por tanto está deshabilitado por omisión.
N: Vea la página de manual apt-secure(8) para los detalles sobre la creación de repositorios y la configuración de usuar
ios.
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
  libauparse0t64
Se instalarán los siguientes paquetes NUEVOS:
  audispd-plugins auditd libauparse0t64
0 actualizados, 3 nuevos se instalarán, 0 para eliminar y 16 no actualizados.
Se necesita descargar 312 kB de archivos.
Se utilizarán 1.024 kB de espacio de disco adicional después de esta operación.
Des:1 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 libauparse0t64 amd64 1:3.1.2-2.1build1.1 [58,9 kB]
Des:2 http://mx.archive.ubuntu.com/ubuntu noble-updates/main amd64 auditd amd64 1:3.1.2-2.1build1.1 [215 kB]
Des:3 http://mx.archive.ubuntu.com/ubuntu noble-updates/universe amd64 audispd-plugins amd64 1:3.1.2-2.1build1.1 [38,8 k
B]
Descargados 312 kB en 1s (213 kB/s)
```

Ilustración 47 - Instalación de auditd

```

GNU nano 7.2 /etc/audit/rules.d/audit.rules *
## First rule - delete all
-D

## Increase the buffers to survive stress events.
## Make this bigger for busy systems
-b 8192

## This determine how long to wait in burst of events
--backlog_wait_time 60000

## Set failure mode to syslog
-f 1

# Monitorear cambios en archivos de identidad
-w /etc/passwd -p wa -k identity
-w /etc/group -p wa -k identity
-w /etc/shadow -p wa -k identity

#Monitorear escalacion de privilegios
-w /etc/sudoers -p wa -k actions

#Monitorear ejecucion de comandos
-a always,exit -F arch=b64 -S execve -k exec_commands

#Hacer las reglas inmutables
-e 2

```

Ilustración 48 - Configuración de las reglas

Generación de reportes con aureport –summary, para ver los resultados de la auditoria.

```

redes2@redes2:~$ sudo ausearch -k identity --start today
-----
time->Fri Mar 20 23:56:18 2026
type=PROCTITLE msg=audit(1774072578.182:198): proctitle=2F7362696E2F617564697463746C002D52002F6574632F61756469742F617564
69742E72756C6573
type=SYSCALL msg=audit(1774072578.182:198): arch=c000003e syscall=44 success=yes exit=1076 a0=3 a1=7ffeb43ce7b0 a2=434 a
3=0 items=0 ppid=13742 pid=13756 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=
4294967295 comm="auditctl" exe="/usr/sbin/auditctl" subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(1774072578.182:198): auid=4294967295 ses=4294967295 subj=unconfined op=add_rule key="identi
ty" list=4 res=1
-----
time->Fri Mar 20 23:56:18 2026
type=PROCTITLE msg=audit(1774072578.182:199): proctitle=2F7362696E2F617564697463746C002D52002F6574632F61756469742F617564
69742E72756C6573
type=PATH msg=audit(1774072578.182:199): item=0 name="/etc/" inode=262145 dev=08:02 mode=040755 ouid=0 ogid=0 rdev=00:00
 nametype=PARENT cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1774072578.182:199): cwd="/"
type=SOCKADDR msg=audit(1774072578.182:199): saddr=1000000000000000000000000000000000
type=SYSCALL msg=audit(1774072578.182:199): arch=c000003e syscall=44 success=yes exit=1076 a0=3 a1=7ffeb43ce7b0 a2=434 a
3=0 items=1 ppid=13742 pid=13756 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=
4294967295 comm="auditctl" exe="/usr/sbin/auditctl" subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(1774072578.182:199): auid=4294967295 ses=4294967295 subj=unconfined op=add_rule key="identi
ty" list=4 res=1
-----
time->Fri Mar 20 23:56:18 2026
type=PROCTITLE msg=audit(1774072578.182:200): proctitle=2F7362696E2F617564697463746C002D52002F6574632F61756469742F617564
69742E72756C6573
type=PATH msg=audit(1774072578.182:200): item=0 name="/etc/" inode=262145 dev=08:02 mode=040755 ouid=0 ogid=0 rdev=00:00
 nametype=PARENT cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1774072578.182:200): cwd="/"
type=SOCKADDR msg=audit(1774072578.182:200): saddr=1000000000000000000000000000000000
type=SYSCALL msg=audit(1774072578.182:200): arch=c000003e syscall=44 success=yes exit=1076 a0=3 a1=7ffeb43ce7b0 a2=434 a
3=0 items=1 ppid=13742 pid=13756 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=

```

Ilustración 49 - Logs de la auditoria


```
redes2@redes2:~$ sudo aureport --summary

Summary Report
=====
Range of time in logs: 20/03/26 23:51:44.087 - 20/03/26 23:58:09.035
Selected time for report: 20/03/26 23:51:44 - 20/03/26 23:58:09.035
Number of changes in configuration: 12
Number of changes to accounts, groups, or roles: 2
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 3
Number of terminals: 8
Number of host names: 2
Number of executables: 9
Number of commands: 9
Number of files: 15
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 6
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 3
Number of process IDs: 23
Number of events: 78
```

Ilustración 50 - Reusmen de la auditoria

CONCLUSIÓN

Esta práctica cambió mi perspectiva sobre la seguridad Linux. Partimos de un sistema estándar con índice de hardening de 57 y llegamos a 69 puntos, no es un salto espectacular, pero cada punto representaba una vulnerabilidad menos. Lo que aprendí fue más importante que los números: la seguridad no viene de una sola herramienta sino de capas. Lynis detecta grietas. OpenSCAP verifica que las reparaciones se mantengan. Auditd registra quién hizo qué y cuándo.

El hardening de kernel con sysctl y nftables no son configuraciones opcionales. Cuando deshabilitamos io_uring o aplicamos ASLR, directamente hicimos que los exploits conocidos dejen de funcionar. SSH con criptografía post-cuántica no es un lujo para el futuro, es defensa hoy contra ataques que serán descifrados en 15 años. Y el análisis de contenedores con Trivy fue revelador: Alpine Linux, la imagen "segura", tenía vulnerabilidades críticas en zlib.

Al final podemos decir que esto es realista, no existe un sistema totalmente seguro. Lo que existe es una postura de defensa que hace que los ataques sean más costosos, más lento y más ruidosos. Eso es suficiente.

¿CÓMO PUEDO GENERAR UN INGRESO ECONÓMICO A PARTIR DE LO VISTO EN LA PRÁCTICA?

Hay varios caminos. El más rápido: cursos. Plataformas como Udemy o Coursera generan ingresos pasivos (\$1,000–\$5,000 mensuales) si se hace un buen curso sobre "Hardening Linux" o "Auditoría de Seguridad con OpenSCAP". La demanda existe.

El segundo camino es más escalable, herramientas. Se pueden desarrollar playbooks Ansible o scripts Terraform que automaticen el hardening, venderlos como SaaS con suscripción mensual (\$50–\$200). O especializarte en auditorías CIS específicas y facturar \$2,000–\$5,000 por proyecto.

Si primero quiero trabajar como empleado, roles como Security Engineer o DevSecOps en México pagan \$1,500–\$2,500 USD mensuales (más en Latinoamérica o remoto). Si se trabaja independiente, una estrategia buena es comenzar con auditorías básicas a pequeñas empresas por \$500–\$1,000 para construir portafolio, luego escalar a auditorías complejas.

En caso de querer emprender, lo que funciona mejor es combinar las primeras dos opciones. Hacer un curso que llegue a 1,000 estudiantes. De esos, algunos necesitan implementación real y se cobra por servicios. Algunos quieren tooling personalizado. Crear una herramienta. Es menos limpio que una sola fuente de ingresos, pero la demanda en ciberseguridad es lo suficientemente grande como para sostener múltiples modelos.